

Scenario - Attacco informatico e sicurezza compromessa

Marketing

Poichè è stato rilevato un attacco informatico ed è stata violata la sicurezza, è necessario:

- ➔ Informare il Direttore dell'accaduto;
- ➔ Non divulgare la notizia dell'accaduto;
- ➔ Mettersi subito in contatto con il legale dell'azienda per cercare di limitare il danno

Forniamo un messaggio per i membri dell'azienda nel quale spieghiamo l'accaduto.

“Durante la notte tra sabato e domenica, è stato rilevato un segnale di accesso anomalo proveniente da un IP esterno. Sono stati copiati alcuni file ed è stato rilevato l'accesso ad alcune cartelle contenenti dati sensibili di clienti. Stiamo già lavorando con i nostri legali e con il team di sicurezza per contenere i danni. È richiesta la massima riservatezza.”

Monitoriamo la situazione anche nel lato social media. Infatti, dagli esperti aziendali, vengono controllate le piattaforme social in cerca di qualche fuga di dati o di notizie provenienti da esterni.

Se è stata divulgata la notizia, è necessario informare la stampa dell'accaduto attraverso:

- ➔ Comunicando ufficialmente con la stampa
- ➔ Mettendoci in comunicazione attraverso email ufficiali con i clienti
- ➔ Aggiornamenti immediati al CEO dell'azienda

Inoltre forniamo un messaggio da divulgare, su tutti i sistemi di informazione, alla stampa nel quale andiamo a spiegare l'accaduto e come stiamo gestendo il problema in modo da non rovinare la figura reputazionale dell'azienda.

“Abbiamo rilevato un accesso non autorizzato ai nostri sistemi durante la notte tra sabato e domenica. Sono stati copiati dei file conservati in un sistema di backup il quale non riceveva aggiornamenti da più di 3 mesi. Le nostre squadre stanno lavorando con esperti per valutare l'entità dell'accaduto e rafforzare le misure di sicurezza. Al momento non ci sono evidenze di un uso improprio dei dati. Informeremo tempestivamente i nostri clienti qualora emergano nuove informazioni.”

Per riuscire a non perdere la credibilità dell'azienda e la reputazione, forniamo informazioni con aggiornamenti continui con i nostri clienti attraverso l'utilizzo di e-mail con livello di priorità massima nel quale forniamo informazioni con termini non troppo tecnici ma capibili e leggibili da tutti.

Legale:

- 1- Individuare problemi in base al proprio ambito
- 2- Strategia in base al ruolo per tamponare la situazione
-tipo di attacco, info a rischio
3. Responsabile Legale/Privacy

-Valutare impatti GDPR e obblighi di notifica al Garante -> GDPR: Regolamento Europeo sulla protezione dei dati personali. Impone l'obbligo di notifica al Garante in caso di violazione di dati sensibili.
-Redigere comunicazione per stakeholder e clienti (se necessaria) -> Comunicazione di crisi: messaggio ufficiale usato per informare clienti, stampa e stakeholder in caso di incidenti aziendali gravi.
-> Esfiltrazione di dati: furto o copia non autorizzata di dati da un sistema informatico verso l'esterno.

Partecipare al team di crisi insieme a IT, sicurezza, comunicazione e vertici aziendali.
Valutare l'impatto legale preliminare dell'attacco e verificare se si necessita di un eventuale notifica alle autorità e ad eventuali clienti,aziende (entro e non oltre le 70 ore)
Verificare i contratti con fornitori, clienti e partner per valutare obblighi e responsabilità in caso di violazione (Se i dati compromessi li riguardano, gestire la comunicazione trasparente, nei tempi e nei modi richiesti dalla legge).
Identificare eventuali responsabilità interne (o se è presente il reato di associazione a delinquere)
Pensare ad un eventuale risarcimento basandomi su contratti ed eventuali assicurazioni stipulate dai clienti.

CTO:

il CTO assume un ruolo cruciale nella gestione della crisi, coordinando la risposta e garantendo la continuità operativa. Le sue principali responsabilità includono la valutazione dell'incidente, la gestione delle risorse tecniche.

- determinare il perché è avvenuto l'attacco
- controllare i log eseguiti durante l'attacco per vedere chi ha avuto accesso al server
- controllare lo stato attuale del server per controllare altri possibili danni
- ripristino del server tramite backup per recuperare possibili dati persi
- controllo aggiornamenti per vedere se non sono stati eseguiti aggiornamenti
- vedere chi era il responsabile per la manutenzione del server e segnalare i possibili colpevoli
- riorganizzare la squadra di manutenzione

Cyberscurity (Riccardo):

il responsabile di Cyber Security analizza la situazione e comincia a studiare l'attacco in modo da limitare la fuga dei dati, o se possibile, bloccare completamente l'attacco, aggiornando il server e rendendolo più sicuro. Tra le principali informazioni raccolte vi sono:

- Data e ora accesso sospetto: 02:17, notte tra sabato e domenica (serve a capire se si fa ancora in tempo a difendere l'azienda dall'attacco)
- IP tracciato: localizzazione extra-UE (serve per capire da dove può venire l'attacco e in tal caso scoprire chi è stato)

- File coinvolti: report vendite e archivio clienti (serve a capire se sono stati presi di mira determinati clienti e se vi è uno schema che li collega)
- Durata accesso: 37 minuti continuativi (serve a capire quanti dati sono stati copiati)
- Server coinvolto: backup cloud secondario, aggiornamenti sospesi da 3 mesi
- Software antivirus e IDS attivi, ma non configurati correttamente

(serve a capire quale è stato il punto debole del sistema, per poi eventualmente rinforzarlo)

Collaborazione con le altre figure dell'azienda:

Collaborazione con il CTO: Lavora con il CTO per fermare l'attacco in corso, analizzare la vulnerabilità sfruttata e applicare le patch necessarie per prevenire ulteriori compromissioni.

Collaborazione con il responsabile legale: Fornisce dettagli tecnici sul tipo di attacco, sulla natura dei dati rubati e sulla gravità della violazione, per supportare il team legale nella gestione delle implicazioni giuridiche (ad esempio, la notifica alle autorità competenti, come previsto dal GDPR).

Collaborazione con il CEO: Mantiene il CEO aggiornato sull'incidente, fornendo report sulle azioni intraprese e sulle conseguenze dell'attacco, assicurandosi che le decisioni aziendali siano basate su informazioni accurate.

Collaborazione con il responsabile delle comunicazioni e marketing: Informa il responsabile delle comunicazioni riguardo all'incidente in modo che possieda tutte le informazioni necessarie per gestire la comunicazione esterna e interna.

Cybersecurity (Nicolas):

Nella notte, alle 02:17, il nostro sistema di monitoraggio ha rilevato un accesso anomalo proveniente da un indirizzo IP estero (fuori dall'UE). L'intrusione ha interessato un server cloud secondario, utilizzato per i backup, su cui erano presenti:

Report di vendita

Archivio clienti con dati sensibili

L'attaccante è rimasto attivo per 37 minuti, durante i quali sono stati copiati file e probabilmente consultati dati riservati. Al momento, non abbiamo conferma di una fuga di dati, ma il rischio è elevato.

Vulnerabilità sfruttate:

Il server non era aggiornato da 3 mesi (patch di sicurezza mancanti).

L'antivirus e l'IDS (sistema di rilevamento intrusioni) erano attivi ma configurati in modo non ottimale.

Possibile credenziale compromessa (in fase di verifica).

2. Misure Immediate di Contenimento

Per limitare i danni e prevenire escalation, propongo:

Isolamento del server compromesso: Disconnessione dalla rete per evitare ulteriori accessi.

Analisi forense: Verifica dei log per ricostruire l'attacco e identificare l'entry point.

Cambio delle credenziali d'accesso: Reset di tutte le password e attivazione dell'autenticazione a più fattori.

Patch urgenti: Aggiornamento di tutti i sistemi con vulnerabilità note.

3. Audit e Prevenzione Futura

Per evitare nuovi episodi, è fondamentale:

Rivedere la configurazione di sicurezza (antivirus, IDS, firewall).

Formazione urgente del personale su phishing e best practice.

Pianificare aggiornamenti automatici e test di penetrazione periodici.

4. Conclusione

Questo incidente è un campanello d'allarme che dimostra quanto sia critica una sicurezza proattiva. La mia proposta è:

Contenimento immediato

Investire in formazione e tecnologie per ridurre i rischi futuri.